Contents

Volume 01 — Networking Foundations (L01–L10) **1**
L1: Introduction to Ethical Hacking 1
L2: Basic Concepts of Networking — Part I 2
L3: Basic Concepts of Networking — Part II 2
L4: TCP/IP Protocol Stack — Part I 3
L5: TCP/IP Protocol Stack — Part II 3
L6: IP Addressing and Routing — Part I 4
L7: IP Addressing and Routing — Part II 4
L8: TCP and UDP — Part I 5
L9: TCP and UDP — Part II 6
L10: IP Subnetting 6

Volume 01 — Networking Foundations (L01–L10)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Ethical hacking intro, OSI/TCP-IP, IP addressing, TCP/UDP, subnetting — concepts only.

L1: Introduction to Ethical Hacking

What it is / what it does

- **Hacking** = creative problem-solving applied to systems; **ethical hacking** = authorized security assessment with written permission.
- **Threat actors:** script kiddies, hacktivists, insiders, organized crime, nation-states.
- **Security goals (CIA triad):** Confidentiality, Integrity, Availability (+ Authentication, Non-repudiation).
- **Penetration testing phases:** Reconnaissance → Scanning → Gaining Access → Maintaining Access → Covering Tracks → Reporting.
- **Legal framework:** scope of engagement, rules of engagement (RoE), liability waiver.

Defenses (one-liners)

- Security policy and acceptable-use agreements
- Bug bounty / responsible disclosure programs
- Defense-in-depth architecture
- Regular third-party audits

Exam lines

- Ethical hacking requires **explicit written permission**; unauthorized access is a criminal offense.

- CIA triad is the foundation of information security objectives.
- Pentest phases: recon, scan, exploit, maintain, report.
- White-hat vs black-hat vs grey-hat distinction.
- CVSS scores rate vulnerability severity (0–10).

L2: Basic Concepts of Networking — Part I

What it is / what it does

- **Network types:** LAN, MAN, WAN; client-server vs peer-to-peer.
- **OSI 7-layer model:** Physical → Data Link → Network → Transport → Session → Presentation → Application.
- **PDU names:** bits, frames, packets, segments, data.
- **Topologies:** bus, star, ring, mesh, hybrid.
- **Transmission media:** twisted pair (UTP/STP), coaxial, fiber optic, wireless.

Defenses (one-liners)

- Replace hubs with switches (microsegmentation)
- VLAN segmentation
- Physical port security (802.1X)

Exam lines

- OSI Layer 3 = Network (routing); Layer 4 = Transport (TCP/UDP).
- Star topology: single switch failure isolates nodes; mesh is most fault-tolerant.
- LAN = local; WAN spans geographic distances.
- ping uses ICMP Echo Request/Reply (Layer 3).
- PDU at Data Link layer is a **frame**.

L3: Basic Concepts of Networking — Part II

What it is / what it does

- **MAC address:** 48-bit hardware address (OUI + NIC-specific); flat namespace.
- **Ethernet frame structure:** preamble, dest/src MAC, type/length, payload, FCS.
- **CSMA/CD** (legacy Ethernet): collision detection on shared bus.
- **Switches:** learn MAC→port via CAM table; forward unicast, flood unknown/broadcast.
- **VLANs (802.1Q):** logical segmentation; tag inserted in frame header.

Defenses (one-liners)

- Port security (limit MACs per port)
- Dynamic ARP Inspection (DAI)
- VLAN access control lists

Exam lines

- Switch operates at **Layer 2**; router at **Layer 3**.
- CAM table maps MAC address → switch port.
- Broadcast MAC = FF:FF:FF:FF:FF:FF.
- 802.1Q VLAN tag is 4 bytes inserted in Ethernet frame.
- MAC flooding causes switch to flood frames to all ports (fail-open).

L4: TCP/IP Protocol Stack — Part I

What it is / what it does

- **TCP/IP model (4 layers):** Network Access → Internet → Transport → Application.
- Maps loosely to OSI: Layers 1–2 → Network Access; Layer 3 → Internet; Layer 4 → Transport; Layers 5–7 → Application.
- **Encapsulation:** each layer adds its header (and sometimes trailer) to data from layer above.
- **Internet layer protocols:** IP (v4/v6), ICMP, IGMP, ARP.
- **IP datagram:** version, header length, TTL, protocol field, src/dst address, payload.

Defenses (one-liners)

- Encrypt at Transport (TLS) or Application layer
- Network segmentation to limit broadcast domains
- Egress filtering

Exam lines

- TCP/IP has **4 layers**; OSI has **7**.
- IP operates at Internet layer; provides logical addressing only (no reliability).
- TTL field prevents infinite routing loops (decremented per hop).
- Protocol field in IP header identifies TCP (6) or UDP (17).
- Encapsulation: Application data → TCP segment → IP packet → Ethernet frame.

L5: TCP/IP Protocol Stack — Part II

What it is / what it does

- **Application layer protocols:** HTTP (80), HTTPS (443), DNS (53), SMTP (25), FTP (21), SSH (22), Telnet (23).
- **Socket API:** (IP address, port number, protocol) uniquely identifies endpoint.
- **Well-known ports:** 0–1023; registered 1024–49151; dynamic/ephemeral 49152–65535.
- **DNS resolution:** recursive (client→resolver) vs iterative (resolver→root→TLD→authoritative).
- **DHCP (DORA):** Discover, Offer, Request, Acknowledge — auto IP configuration.

Defenses (one-liners)

- DNSSEC (signed DNS responses)
- Disable zone transfers (AXFR) to unauthorized clients
- Split-horizon DNS for internal vs external views

Exam lines

- DNS uses **UDP port 53** (TCP for large transfers/zone transfers).
- DHCP provides IP, subnet mask, gateway, and DNS server.
- Socket = IP + port + protocol (TCP/UDP).
- Telnet (port 23) transmits credentials in cleartext — never use in production.

L6: IP Addressing and Routing — Part I

What it is / what it does

- **IPv4 address:** 32 bits, dotted-decimal notation (e.g., 192.168.1.10).
- **Address classes (legacy):** A (0–127), B (128–191), C (192–223); classless CIDR replaced this.
- **Private ranges (RFC 1918):** 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16.
- **Special addresses:** loopback 127.0.0.0/8, link-local 169.254.0.0/16, broadcast (host bits all 1s).
- **Static vs dynamic** addressing; NAT maps private→public.

Defenses (one-liners)

- Network Address Translation (hide internal topology)
- RFC 1918 addressing with firewall rules
- IP allowlisting for management interfaces

Exam lines

- Private ranges: 10.x, 172.16–31.x, 192.168.x (RFC 1918).
- Loopback = 127.0.0.1; used for local service testing.
- CIDR notation: IP/prefix-length (e.g., /24 = 255.255.255.0).
- NAT translates private IPs to one public IP (PAT/overloading).
- Classless addressing (CIDR) replaced classful A/B/C.

L7: IP Addressing and Routing — Part II

What it is / what it does

- **Routing table entries:** destination network, next-hop, interface, metric.
- **Default gateway:** route for all non-local destinations (0.0.0.0/0).
- **Static routing:** manually configured; predictable but inflexible.
- **Dynamic routing:** routers exchange topology via routing protocols.

- **Longest prefix match:** most specific route wins when multiple match.

Defenses (one-liners)

- Route authentication (OSPF MD5, BGP MD5/TCP-AO)
- Filter routing updates at edge
- Disable unnecessary routing protocols on endpoints

Exam lines

- Default route = 0.0.0.0/0 pointing to gateway.
- Longest prefix match selects the most specific route.
- Static routes: admin-configured; no auto-failover.
- Traceroute exploits ICMP Time Exceeded (TTL expiry) messages.
- Host uses routing table to decide local delivery vs forwarding to gateway.

L8: TCP and UDP — Part I

What it is / what it does

- **TCP:** connection-oriented, reliable, ordered delivery, flow control, congestion control.
- **Three-way handshake:** SYN → SYN-ACK → ACK (establishes connection).
- **TCP header fields:** src/dst port, seq number, ack number, flags (SYN/ACK/FIN/RST/PSH), window size.
- **UDP:** connectionless, no guarantee of delivery, no ordering, lower overhead.
- **Use cases:** TCP = HTTP, SSH, FTP; UDP = DNS, VoIP, streaming, gaming.

Defenses (one-liners)

- SYN cookies (mitigate SYN flood)
- Stateful firewall (track connection state)
- Disable unnecessary services

Exam lines

- TCP 3-way handshake: SYN (seq=x) → SYN-ACK (seq=y, ack=x+1) → ACK (ack=y+1).
- SYN scan is stealthier than connect scan (no full connection).
- UDP has no handshake; stateless and faster but unreliable.
- TCP sequence numbers enable ordered, reliable delivery.
- RST flag immediately terminates a TCP connection.

L9: TCP and UDP — Part II

What it is / what it does

- **TCP connection teardown:** FIN → ACK → FIN → ACK (four-way) or RST for abrupt close.
- **TCP state machine:** CLOSED → SYN_SENT → ESTABLISHED → FIN_WAIT → CLOSED.
- **Flow control:** sliding window, receiver advertises window size.
- **Congestion control:** slow start, congestion avoidance, fast retransmit (TCP Reno/CUBIC).
- **Port scanning types:** SYN, connect, FIN, NULL, Xmas, ACK, UDP.

Defenses (one-liners)

- IDS/IPS detecting scan patterns
- Rate limiting on SYN packets
- Close unused ports; use port knocking for admin access

Exam lines

- FIN scan: send FIN packet; closed port → RST, open port → no response (RFC-compliant).
- Filtered port: firewall drops probe — nmap reports “filtered.”
- UDP scanning is slower and less reliable than TCP scanning.
- TCP sliding window provides flow control between sender and receiver.
- Four-way teardown uses FIN and ACK flags in both directions.

L10: IP Subnetting

What it is / what it does

- **Subnet mask:** separates network prefix from host portion (e.g., /24 = 255.255.255.0).
- **Subnetting:** divide a network into smaller broadcast domains.
- **CIDR calculation:** number of hosts = 2^(32-prefix) − 2 (subtract network and broadcast).
- **VLSM:** Variable Length Subnet Mask — different subnet sizes in same network.
- **Supernetting (route aggregation):** combine contiguous subnets into one route advertisement.

Defenses (one-liners)

- Microsegmentation with /26 or smaller subnets
- Network ACLs between subnets
- Monitor ARP traffic for rogue devices

Exam lines

- /24 subnet: 256 addresses, 254 usable hosts.
- /30 subnet: 4 addresses, 2 usable (common for point-to-point links).
- Subnet mask AND IP address = network address.
- VLSM allows efficient IP allocation with different prefix lengths.

Contents

Volume 02 — Routing, Recon & Nessus (L11–L20) **1**
L11: Routing Protocols — Part I . . . 1
L12: Routing Protocols — Part II . . . 2
L13: Routing Protocols — Part III . . . 2
L14: IP Version 6 . . . 3
L15: Routing Examples . . . 3
L16: Demonstration — Part I . . . 4
L17: Demonstration — Part II . . . 4
L18: Demonstration — Part III . . . 5
L19: Nessus Installation . . . 6
L20: How to Use Nessus . . . 6

Volume 02 — Routing, Recon & Nessus (L11–L20)

Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
notes-3 — concept exam notes (what things are / what they do). No lab command dumps.

Routing protocols, IPv6, OSINT/Nmap ideas, Nessus — what each is and does.

L11: Routing Protocols — Part I

What it is / what it does

- **Interior Gateway Protocols (IGP):** used within an autonomous system (AS).
- **RIP (Routing Information Protocol):** distance-vector; metric = hop count; max 15 hops; broadcasts updates every 30s.
- **Distance-vector characteristics:** "routing by rumor"; slow convergence; count-to-infinity problem.
- **Split horizon:** don't advertise route back to the interface it was learned from.
- **Route poisoning:** advertise failed route with metric 16 (infinity) to speed convergence.

Defenses (one-liners)

- Disable RIP on endpoints; use static routes where possible
- RIP authentication (plain-text or MD5)
- ACLs blocking UDP port 520 from untrusted sources

Exam lines

- RIP is a **distance-vector** protocol; metric = hop count (max 15).
- RIP uses **UDP port 520**; updates every 30 seconds.
- Split horizon prevents routing loops in simple topologies.
- Route poisoning sets failed route metric to 16 (unreachable).

- RIP v2 supports CIDR and multicast updates.

L12: Routing Protocols — Part II

What it is / what it does

- **OSPF (Open Shortest Path First):** link-state IGP; uses Dijkstra SPF algorithm.
- **Areas and ABR:** OSPF divides AS into areas; Area 0 = backbone; ABR connects areas.
- **LSA (Link State Advertisement):** routers flood topology database; build complete map.
- **OSPF packet types:** Hello, DBD (Database Description), LSR, LSU, LSAck.
- **Cost metric:** based on interface bandwidth (reference bandwidth / link bandwidth).

Defenses (one-liners)

- OSPF MD5 authentication on all adjacencies
- Passive interfaces on user-facing ports
- Route filtering and stub areas

Exam lines

- OSPF is **link-state**; builds complete topology map (vs RIP's partial view).
- OSPF uses **Dijkstra SPF** algorithm for shortest path.
- Area 0 is the OSPF **backbone**; all areas must connect to it.
- OSPF cost = reference bandwidth / interface bandwidth.
- OSPF Hello packets discover neighbors on same subnet.

L13: Routing Protocols — Part III

What it is / what it does

- **EIGRP (Enhanced IGRP):** Cisco proprietary (now partially open); hybrid (distance-vector + link-state features); DUAL algorithm.
- **BGP (Border Gateway Protocol):** exterior gateway protocol between ASes; path-vector; policy-based routing.
- **BGP attributes:** AS-PATH, NEXT-HOP, LOCAL-PREF, MED — used for route selection.
- **iBGP vs eBGP:** iBGP within same AS; eBGP between different ASes.
- **Convergence:** OSPF/EIGRP converge faster than RIP.

Defenses (one-liners)

- RPKI (Resource Public Key Infrastructure) — cryptographically validate prefix ownership

- BGP prefix filtering at peering edges
- MANRS (Mutually Agreed Norms for Routing Security)

Exam lines

- BGP is **path-vector**; operates between autonomous systems (inter-domain).
- BGP uses **TCP port 179** for peering sessions.
- AS-PATH attribute lists traversed autonomous systems (loop detection).
- EIGRP uses **DUAL** algorithm; supports unequal-cost load balancing.
- BGP hijacking can redirect global traffic to attacker infrastructure.

L14: IP Version 6

What it is / what it does

- **IPv6 address:** 128 bits, hex notation (2001:db8::1); eliminates NAT scarcity.
- **Address types:** unicast, multicast (no broadcast); anycast = nearest unicast.
- **Special addresses:** ::1 (loopback), fe80::/10 (link-local), fc00::/7 (unique local).
- **Neighbor Discovery Protocol (NDP):** replaces ARP; uses ICMPv6 (RS, RA, NS, NA).
- **SLAAC vs DHCPv6:** Stateless Address Autoconfiguration vs managed addressing.

Defenses (one-liners)

- RA Guard (filter rogue RAs on switch ports)
- SEND (Secure Neighbor Discovery) — cryptographically signed NDP
- IPv6 firewall rules (ip6tables/nftables)

Exam lines

- IPv6 address = **128 bits**; written in hexadecimal with : separators.
- NDP replaces **ARP** in IPv6 (uses ICMPv6).
- No broadcast in IPv6; uses **multicast** instead.
- Link-local prefix: **fe80::/10**.
- SLAAC auto-configures address from prefix in Router Advertisement.

L15: Routing Examples

What it is / what it does

- **Worked examples:** computing routing tables for small multi-router topologies.
- **Forwarding decision:** match destination IP against routing table → longest prefix → forward to next-hop.
- **Administrative distance (Cisco):** static=1, EIGRP=90, OSPF=110, RIP=120, external EIGRP=170, iBGP=200.
- **Route summarization:** aggregate /24s into /22 to reduce routing table size.

- **Floating static route:** backup route with higher metric, activated when primary fails.

Defenses (one-liners)

- Consistent security policy on primary and backup paths
- SNMPv3 with authentication
- Route summarization with prefix filtering

Exam lines

- Longest prefix match determines which route entry is used.
- Lower administrative distance = preferred route (Cisco).
- Route summarization reduces routing table size and update traffic.
- Floating static route activates only when primary route fails.
- Next-hop IP is the router to forward packet to (not necessarily final destination).

L16: Demonstration — Part I

What it is / what it does

- **Reconnaissance methodology:** passive (no direct target contact) vs active (generates traffic).
- **WHOIS lookup:** registrar, name servers, contact info, IP ranges.
- **DNS enumeration:** A, AAAA, MX, NS, TXT, SOA records.
- **Google dorking:** site:, filetype:, inurl: operators for OSINT.
- **Social media / job postings:** reveal technology stack and employee info.

Defenses (one-liners)

- Limit DNS zone transfer (AXFR)
- Employee security awareness training
- Minimize public-facing infrastructure details

Exam lines

- Passive recon generates **no traffic** to target (OSINT).
- dnsenum automates subdomain brute-forcing and zone transfer attempts.
- Google dorking uses advanced search operators for information discovery.
- Reconnaissance is the **first phase** of penetration testing.

L17: Demonstration — Part II

What it is / what it does

- **Active scanning:** directly probes target systems (generates logs).

- **Host discovery:** ICMP echo, ARP ping, TCP SYN to port 80/443.
- **Port scanning with Nmap:** identify open ports and running services.
- **Service version detection:** -sV probes banners and matches against nmap-service-probes DB.
- **OS fingerprinting:** -O analyzes TCP/IP stack behavior (TTL, window size, options).

Defenses (one-liners)

- Firewall rules limiting inbound connections
- Port knocking or single-entry bastion host
- IDS/IPS alerting on scan patterns
- Honeypots to detect and misdirect scanners

Exam lines

- -sV enables **service version detection**.
- -O performs **OS fingerprinting** (requires root for raw sockets).
- -A = aggressive scan (OS + version + scripts + traceroute).
- Active scanning **will be logged** by target IDS/firewall.

L18: Demonstration — Part III

What it is / what it does

- **Nmap Scripting Engine (NSE):** Lua scripts for vulnerability detection, brute-force, discovery.
- **Script categories:** auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, vuln.
- **Wireshark for scan analysis:** observe probe packets and target responses.
- **Firewall/IDS evasion:** fragment packets (-f), decoy scans (-D), slow scan (–scan-delay).
- **Output formats:** -oN (normal), -oX (XML), -oG (grepable).

Defenses (one-liners)

- Deep packet inspection (reassembles fragments)
- Rate-based scan detection
- Block NSE script signatures at WAF/IPS
- Log and alert on –script category traffic patterns

Exam lines

- NSE scripts written in **Lua**; run with –script flag.
- Script categories include: **vuln**, **brute**, **discovery**, **exploit**.
- -D RND:10 sends decoy packets to confuse logging.
- -f fragments packets to evade basic IDS rules.
- Wireshark captures reveal exact probe packets for forensic analysis.

L19: Nessus Installation

What it is / what it does

- **Nessus:** Tenable commercial vulnerability scanner (free Home/Essentials tier available).
- **Architecture:** Nessus server (scanner engine) + Nessus Manager (centralized, enterprise) + agents.
- **Scan types:** credentialed (authenticated) vs non-credentialed (remote/black-box).
- **Plugin feed:** vulnerability checks updated regularly (Professional vs Home feed).
- **Lab setup:** install on Kali or dedicated VM; requires registration for activation code.

Defenses (one-liners)

- Limit scanner access to authorized IP ranges
- Use credentialed scans for accurate patch-level assessment
- Schedule scans during maintenance windows
- Segment scanner VM on management VLAN

Exam lines

- Nessus runs as a **web service on port 8834** (HTTPS).
- **Credentialed scans** provide deeper results (patch levels, local checks).
- Plugin feed contains vulnerability check signatures.
- Nessus Essentials limits scanning to **16 IP addresses**.
- Initial plugin compilation is required after first installation.

L20: How to Use Nessus

What it is / what it does

- **Scan workflow:** New Scan → select template → configure targets → launch → review results.
- **Scan templates:** Basic Network Scan, Advanced Scan, Web App Tests, Malware Scan, Policy Compliance.
- **Severity ratings:** Critical, High, Medium, Low, Info (based on CVSS).
- **False positives:** verify findings manually before reporting.
- **Remediation:** Nessus provides CVE references, plugin output, and fix recommendations.

Defenses (one-liners)

- Patch management program addressing Nessus findings
- Compensating controls for unpatchable systems
- Regular rescanning to verify remediation

- WAF/IPS rules for web application findings

Exam lines

- Nessus severity maps to **CVSS scores** (Critical ≥ 9.0, High 7.0–8.9).
- **Advanced Scan** template allows full customization.
- Credentialed scans require SSH/Windows credentials on target.
- Plugin output shows exact check performed and evidence found.
- Always **verify findings** manually to reduce false positives in reports.

Contents

Volume 03 — Metasploit, MITM & Crypto I (L21–L30) **1**
L21: Metasploit — Exploiting System Software I 1
L22: Metasploit — Exploiting System Software II 2
L23: Metasploit — Exploiting System Software and Privilege 2
L24: Metasploit — Social Engineering Attack 3
L25: MITM (Man-in-the-Middle) Attack 3
L26: Basic Concepts of Cryptography 4
L27: Private-Key Cryptography — Part I 4
L28: Private-Key Cryptography — Part II 5
L29: Public-Key Cryptography — Part I 6
L30: Public-Key Cryptography — Part II 6

Volume 03 — Metasploit, MITM & Crypto I (L21–L30)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Exploitation frameworks, social engineering, ARP/MITM, cryptography foundations.

L21: Metasploit — Exploiting System Software I

What it is / what it does

- **Metasploit Framework (MSF):** open-source penetration testing platform by Rapid7.
- **Architecture:** msfconsole (CLI) → modules (exploits, payloads, auxiliaries, encoders, nops, post) → database.
- **Exploit module:** delivers payload against a specific vulnerability (CVE).
- **Payload:** code executed on target after exploitation (shell, meterpreter, VNC).
- **msfvenom:** standalone payload generator and encoder.

Defenses (one-liners)

- Patch management (MS17-010 for EternalBlue)
- Disable SMBv1
- Network segmentation; block inbound SMB (port 445) at perimeter
- EDR detecting Meterpreter behavior

Exam lines

- Metasploit modules: **exploit, payload, auxiliary, encoder, post**.
- msfvenom generates standalone payloads outside msfconsole.
- Meterpreter = advanced in-memory payload with extensible features.
- set RHOSTS = target; set LHOST = attacker callback IP.

L22: Metasploit — Exploiting System Software II

What it is / what it does

- **Auxiliary modules:** scanning, fuzzing, DoS, credential brute-force (no payload delivery).
- **Encoder modules:** obfuscate payload to evade signature-based AV/IDS.
- **NOP generators:** pad payload to avoid bad-character issues.
- **Resource scripts (.rc):** automate sequences of MSF commands.
- **Multi/handler:** catch reverse connections from multiple exploits.

Defenses (one-liners)

- AV with behavioral detection (not just signatures)
- Application whitelisting
- Network monitoring for reverse shell connections
- Disable unnecessary services found by auxiliary scans

Exam lines

- **Auxiliary modules** perform scanning/brute-force without delivering exploits.
- **Encoders** (e.g., shikata_ga_nai) mutate payload to evade detection.
- exploit/multi/handler catches reverse TCP connections.
- Resource scripts automate repetitive msfconsole commands.
- show options displays required/optional module parameters.

L23: Metasploit — Exploiting System Software and Privilege

What it is / what it does

- **Privilege escalation:** gaining higher permissions (user → root/SYSTEM).
- **Post-exploitation modules:** run after initial access (hashdump, enum_users, persistence).
- **Meterpreter commands:** sysinfo, getuid, getsystem, hashdump, migrate.
- **Local exploits:** target OS/kernel vulnerabilities from low-privilege shell.
- **Token impersonation:** steal SYSTEM token on Windows.

Defenses (one-liners)

- Principle of least privilege
- Patch kernel and local privilege escalation CVEs promptly
- Credential Guard / LSA protection (Windows)
- Monitor for suspicious token manipulation

Exam lines

- getsystem attempts multiple techniques to gain SYSTEM on Windows.
- hashdump extracts NTLM password hashes from SAM database.
- **Post modules** run after compromise (enumeration, persistence, exfiltration).
- migrate moves Meterpreter into a more stable process (e.g., explorer.exe).
- local_exploit_suggester recommends kernel exploits based on system info.

L24: Metasploit — Social Engineering Attack

What it is / what it does

- **Social engineering:** manipulating people to divulge info or perform actions.
- **SET (Social Engineering Toolkit):** integrated with Metasploit for phishing campaigns.
- **Attack vectors:** spear phishing, USB drops, fake login pages, SMS phishing (smishing).
- **Credential harvester:** clone legitimate website; capture submitted credentials.
- **Payload delivery via email:** malicious attachment or link to browser exploit.

Defenses (one-liners)

- Security awareness training and phishing simulations
- Email filtering (SPF, DKIM, DMARC)
- MFA on all authentication endpoints
- URL rewriting/proxy for link inspection

Exam lines

- SET integrates with Metasploit for **automated social engineering**.
- Credential harvester **clones websites** to steal login credentials.
- Spear phishing targets **specific individuals** with crafted messages.
- MFA mitigates stolen-credential attacks even after successful harvest.
- Social engineering exploits **human psychology**, not technical vulnerabilities.

L25: MITM (Man-in-the-Middle) Attack

What it is / what it does

- **MITM:** attacker intercepts and potentially alters communication between two parties.
- **ARP spoofing/poisoning:** send fake ARP replies mapping attacker's MAC to victim's gateway IP.
- **DNS spoofing:** redirect DNS queries to attacker-controlled server.
- **SSL stripping:** downgrade HTTPS to HTTP (sslstrip tool).
- **Session hijacking:** capture cookies/tokens from intercepted traffic.

Defenses (one-liners)

- **Static ARP entries** for critical hosts (gateway, DNS)
- **Dynamic ARP Inspection (DAI)** on managed switches
- **HTTPS with HSTS** and certificate pinning
- **802.1X** port authentication

Exam lines

- ARP operates at **Layer 2**; has no authentication — easily spoofed.
- Bidirectional ARP spoofing required: poison victim **and** gateway.
- IP forwarding must be enabled on attacker to relay packets.
- DAI on switches validates ARP packets against DHCP snooping table.
- SSL stripping exploits sites that don't enforce HSTS.

L26: Basic Concepts of Cryptography

What it is / what it does

- **Cryptography goals:** confidentiality, integrity, authentication, non-repudiation.
- **Kerckhoffs's principle:** security relies on key secrecy, not algorithm secrecy.
- **Cryptanalysis:** breaking ciphers without key (brute force, frequency analysis, side channels).
- **Symmetric vs asymmetric:** same key vs key pair (public/private).
- **Steganography vs cryptography:** hiding existence of message vs scrambling content.

Defenses (one-liners)

- Use well-vetted algorithms (AES, SHA-256, RSA-2048+)
- Proper key management (HSM, key rotation)
- Never roll your own crypto
- Use authenticated encryption (AES-GCM, ChaCha20-Poly1305)

Exam lines

- Kerckhoffs's principle: algorithm is public; **key is secret**.
- Symmetric crypto: **one shared key** for encrypt and decrypt.
- Asymmetric crypto: **public key encrypts**, private key decrypts.
- Steganography hides message **existence**; cryptography hides **content**.
- Brute-force complexity grows exponentially with key length.

L27: Private-Key Cryptography — Part I

What it is / what it does

- **Symmetric (private-key) ciphers:** AES, DES, 3DES, Blowfish, RC4.

- **Block ciphers:** encrypt fixed-size blocks (AES = 128-bit blocks).
- **Stream ciphers:** encrypt bit/byte at a time (RC4, ChaCha20).
- **DES:** 56-bit key (obsolete); **3DES:** three DES operations (deprecated).
- **AES (Rijndael):** 128/192/256-bit keys; NIST standard since 2001.

Defenses (one-liners)

- Use AES-256 in GCM or CBC with HMAC
- Never use DES, 3DES, or RC4 in new systems
- Unique IV/nonce per encryption operation
- Key length ≥ 256 bits for long-term security

Exam lines

- AES block size = **128 bits**; key sizes = 128, 192, or 256 bits.
- DES key = **56 effective bits** (64 with parity) — considered broken.
- ECB mode reveals patterns — **never use for structured data**.
- Stream ciphers encrypt data **bit-by-bit** or byte-by-byte.
- 3DES applies DES encrypt-decrypt-encrypt (EDE) with 2 or 3 keys.

L28: Private-Key Cryptography — Part II

What it is / what it does

- **Block cipher modes:** ECB, CBC, CFB, OFB, CTR, GCM.
- **CBC (Cipher Block Chaining):** each block XORed with previous ciphertext; requires unique IV.
- **CTR (Counter mode):** turns block cipher into stream cipher; parallelizable.
- **GCM (Galois/Counter Mode):** authenticated encryption (AEAD) — confidentiality + integrity.
- **Key distribution problem:** symmetric crypto requires secure key exchange channel.

Defenses (one-liners)

- Prefer **AES-GCM** or **ChaCha20-Poly1305** (authenticated encryption)
- Random, unique IV for every CBC/CTR encryption
- Never reuse nonce in GCM (catastrophic failure)
- Use TLS 1.3 for transport encryption

Exam lines

- CBC chains blocks: $C_i = E(P_i \oplus C_{i-1})$; requires unpredictable **IV**.
- GCM provides **authenticated encryption** (confidentiality + integrity).
- CTR mode converts block cipher into **stream cipher**; supports parallel encryption.
- Padding oracle attack exploits **CBC decryption error messages**.
- Symmetric crypto's weakness: **secure key distribution** between parties.

L29: Public-Key Cryptography — Part I

What it is / what it does

- **Asymmetric cryptography:** key pair — public key (encrypt/verify) + private key (decrypt/sign).
- **RSA:** based on factoring large primes; key sizes 2048–4096 bits recommended.
- **Diffie-Hellman (DH):** key exchange protocol; compute shared secret over insecure channel.
- **ECDHE:** Elliptic Curve DH Ephemeral — modern TLS key exchange.
- **One-way functions:** easy to compute forward, infeasible to reverse (factoring, discrete log).

Defenses (one-liners)

- RSA key length ≥ **2048 bits** (3072+ for long-term)
- Use ECDHE with curve P-256 or X25519
- Disable export-grade and weak DH cipher suites
- Rotate keys periodically

Exam lines

- RSA security based on **integer factorization** hardness.
- DH allows **key exchange** without prior shared secret.
- Public key encrypts; **only private key decrypts**.
- ECDHE uses **elliptic curve** math for smaller, faster keys.
- RSA-1024 is deprecated; minimum is **RSA-2048**.

L30: Public-Key Cryptography — Part II

What it is / what it does

- **Hybrid encryption:** asymmetric for key exchange + symmetric for bulk data (TLS model).
- **RSA padding schemes:** PKCS#1 v1.5, OAEP (prevent chosen-ciphertext attacks).
- **ElGamal:** encryption based on discrete logarithm problem.
- **Elliptic Curve Cryptography (ECC):** same security as RSA with smaller keys (P-256 ≈ RSA-3072).
- **Key management:** PKI, certificate authorities, certificate chains (covered L33).

Defenses (one-liners)

- Use RSA-OAEP or ECIES for encryption
- Validate elliptic curve points in ECDH implementations
- Hardware RNG or OS CSPRNG for key generation
- Certificate pinning for critical applications

Exam lines

- Hybrid encryption: **asymmetric exchanges key**, symmetric encrypts data.
- ECC P-256 provides security equivalent to **RSA-3072** with smaller keys.
- OAEP padding prevents **chosen-ciphertext attacks** on RSA.
- ElGamal encryption based on **discrete logarithm** problem.
- TLS uses hybrid model: ECDHE key exchange + AES-GCM bulk encryption.

Contents

Volume 04 — Hash, PKI & Network Attacks (L31–L40) **1**
L31: Cryptographic Hash Functions — Part I 1
L32: Cryptographic Hash Functions — Part II 2
L33: Digital Signature and Certificate 2
L34: Applications — Part I 3
L35: Applications — Part II 3
L36: Steganography 4
L37: Biometrics 5
L38: Network Based Attacks — Part I 5
L39: Network Based Attacks — Part II 6
L40: DNS and Email Security 6

Volume 04 — Hash, PKI & Network Attacks (L31–L40)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Hash functions, signatures, steganography, biometrics, DNS/email security.

L31: Cryptographic Hash Functions — Part I

What it is / what it does

- **Hash function:** maps arbitrary-length input to fixed-length digest; one-way, deterministic.
- **Properties:** preimage resistance, second-preimage resistance, collision resistance.
- **MD5:** 128-bit output; **broken** for collision attacks (do not use for security).
- **SHA-1:** 160-bit output; deprecated (SHAttered collision demonstrated 2017).
- **SHA-2 family:** SHA-256, SHA-384, SHA-512; current standard (NIST FIPS 180-4).

Defenses (one-liners)

- Use SHA-256 or SHA-3 for integrity verification
- **Salt** passwords before hashing (unique per user)
- Use HMAC or bcrypt/scrypt/Argon2 for password storage
- Deprecate MD5 and SHA-1 in all security contexts

Exam lines

- Hash function properties: **one-way, deterministic, collision-resistant**.
- MD5 output = **128 bits** (32 hex chars); cryptographically broken.
- SHA-256 output = **256 bits** (64 hex chars); current standard.
- Salting prevents **rainbow table** attacks on password hashes.

- Preimage resistance: given hash, cannot find original input.

L32: Cryptographic Hash Functions — Part II

What it is / what it does

- **SHA-3 (Keccak):** sponge construction; different internal design from SHA-2 (safety net).
- **HMAC:** Hash-based MAC = H(K ⊕ opad, H(K ⊕ ipad, message)); provides integrity + authentication.
- **Password hashing:** bcrypt, scrypt, Argon2 — deliberately slow + salted (resist brute-force).
- **Merkle-Damgård construction:** iterative hashing used by MD5, SHA-1, SHA-2.
- **Birthday attack:** find collision in ~2^(n/2) operations for n-bit hash.

Defenses (one-liners)

- Argon2id for password storage (winner of Password Hashing Competition)
- HMAC-SHA256 for message authentication codes
- Full hash output (no truncation below 128 bits)
- Rate limiting on authentication endpoints

Exam lines

- Birthday attack complexity: **2^(n/2)** for n-bit hash.
- HMAC = hash + secret key → provides **authentication + integrity**.
- bcrypt/scrypt/Argon2 are **adaptive** — configurable work factor.
- SHA-3 uses **sponge construction** (not Merkle-Damgård).
- Never store passwords as plain SHA-256 — always use **salt + slow hash**.

L33: Digital Signature and Certificate

What it is / what it does

- **Digital signature:** hash of message encrypted with sender's private key; proves origin + integrity.
- **Verification:** decrypt signature with public key → compare hash of received message.
- **X.509 certificate:** binds public key to identity; signed by Certificate Authority (CA).
- **PKI hierarchy:** Root CA → Intermediate CA → End-entity certificate.
- **Certificate fields:** subject, issuer, validity period, public key, serial number, extensions.

Defenses (one-liners)

- Use trusted public CAs (Let's Encrypt, DigiCert)

- Certificate pinning (HPKP deprecated; use Expect-CT, CAA records)
- OCSP stapling for revocation checking
- Short certificate validity (90 days — Let's Encrypt standard)

Exam lines

- Digital signature uses sender's **private key**; verified with **public key**.
- X.509 certificate binds **identity to public key**, signed by CA.
- PKI chain: Root CA → Intermediate → End-entity.
- Self-signed certs are **not trusted** by default in browsers.
- OCSP checks if certificate has been **revoked** before expiry.

L34: Applications — Part I

What it is / what it does

- **SSL/TLS:** secure transport layer; versions TLS 1.2 and 1.3 current; SSLv3/TLS 1.0/1.1 deprecated.
- **TLS handshake:** ClientHello → ServerHello → Certificate → Key Exchange → Finished.
- **Cipher suite:** key exchange + authentication + bulk encryption + MAC (e.g., TLS_AES_256_GCM_SHA384).
- **Perfect Forward Secrecy (PFS):** ephemeral DH keys — compromise of long-term key doesn't decrypt past sessions.
- **IPsec:** network-layer security; modes: Transport (host-to-host) and Tunnel (gateway-to-gateway).

Defenses (one-liners)

- Enforce TLS 1.2+ only; prefer TLS 1.3
- Disable weak ciphers (RC4, 3DES, NULL, EXPORT)
- Enable HSTS header: Strict-Transport-Security:
- Use ECDHE cipher suites for forward secrecy

Exam lines

- TLS provides **confidentiality + integrity** at transport layer.
- TLS 1.3 reduces handshake to **1-RTT** (faster than TLS 1.2's 2-RTT).
- PFS ensures past sessions safe even if **long-term key compromised**.
- IPsec **Tunnel mode** encrypts entire IP packet (VPN use case).
- Cipher suite specifies: key exchange, authentication, encryption, MAC algorithms.

L35: Applications — Part II

What it is / what it does

- **PGP/GPG:** email encryption and signing; web of trust model (vs PKI hierarchy).

- **S/MIME:** email encryption using X.509 certificates (enterprise standard).
- **VPN protocols:** IPsec (IKEv2), OpenVPN (SSL/TLS), WireGuard (modern, lightweight).
- **SSH:** secure remote shell; key-based auth preferred over passwords.
- **Kerberos:** network authentication using tickets (Active Directory).

Defenses (one-liners)

- SSH key-based auth with Ed25519 keys; disable password auth
- GPG key passphrase protection; hardware token (YubiKey)
- Kerberos AES encryption; monitor for TGS-REQ anomalies
- VPN MFA + certificate-based authentication

Exam lines

- PGP uses **web of trust**; S/MIME uses **PKI/X.509**.
- SSH default port = **22**; key-based auth more secure than passwords.
- Kerberos uses **tickets** (TGT + service tickets) for authentication.
- OpenVPN tunnels traffic over **SSL/TLS** (port 443/UDP 1194).
- WireGuard is a modern VPN using **Curve25519** key exchange.

L36: Steganography

What it is / what it does

- **Steganography:** hiding secret data within innocuous carrier (image, audio, video, text).
- **LSB (Least Significant Bit):** replace least significant bits of pixel values with secret bits.
- **Steganalysis:** detecting hidden data via statistical analysis (chi-square, RS analysis).
- **Tools hide data in:** image formats (BMP, PNG), audio (WAV), documents (PDF).
- **Difference from encryption:** steganography conceals **existence**; encryption conceals **content**.

Defenses (one-liners)

- Re-encode images (destroys LSB steganography)
- DLP scanning for anomalous file entropy
- Monitor outbound file transfers for unusual patterns
- Hash comparison of known-clean vs suspect media

Exam lines

- LSB steganography modifies **least significant bits** of pixel values.
- Steganography hides message **existence**; cryptography hides **content**.
- steghide supports JPEG and BMP with optional passphrase encryption.
- Chi-square test detects **non-random LSB distribution** (steganalysis).

- binwalk identifies and extracts embedded files by signature scanning.

L37: Biometrics

What it is / what it does

- **Biometric modalities:** fingerprint, iris, face, voice, gait, palm print.
- **Performance metrics:** FAR (False Accept Rate), FRR (False Reject Rate), EER (Equal Error Rate).
- **Liveness detection:** distinguish live person from photo/mold/replay attack.
- **Template storage:** store feature vectors, not raw images; irreversible transforms preferred.
- **Multimodal biometrics:** combine two+ modalities for higher accuracy.

Defenses (one-liners)

- Liveness detection (blink, pulse, challenge-response)
- Cancelable biometrics (revocable templates)
- Multimodal fusion (fingerprint + iris)
- Store templates with homomorphic encryption or secure enclave

Exam lines

- FAR = unauthorized user **accepted**; FRR = authorized user **rejected**.
- EER = point where FAR equals FRR (lower is better).
- Biometric templates **cannot be changed** if compromised (unlike passwords).
- Liveness detection prevents **presentation attacks** (spoofing).
- Multimodal biometrics improves accuracy by combining modalities.

L38: Network Based Attacks — Part I

What it is / what it does

- **Sniffing:** capture packets on network segment (promiscuous mode).
- **Spoofing types:** IP spoofing, MAC spoofing, email spoofing, DNS spoofing.
- **Session hijacking:** take over established TCP session using stolen seq/ack numbers.
- **TCP RST attack:** send forged RST to tear down connection.
- **DNS cache poisoning:** inject false DNS records into resolver cache.

Defenses (one-liners)

- Switches (not hubs) + port security
- Encrypt traffic (TLS everywhere)
- DNSSEC prevents cache poisoning
- Randomized TCP ISN (initial sequence numbers)

Exam lines

- Promiscuous mode captures **all frames** on segment (not just addressed to host).
- DNS cache poisoning injects **false records** into resolver cache.
- TCP session hijacking requires knowing/c predicting **sequence numbers**.
- IP spoofing: forge source IP (used in DDoS reflection attacks).
- Switches limit sniffing to own port traffic (unless ARP spoofed or MAC flooded).

L39: Network Based Attacks — Part II

What it is / what it does

- **Firewall types:** packet-filtering (stateless), stateful inspection, application-layer (proxy).
- **IDS (Intrusion Detection):** passive monitoring, alerts on suspicious patterns (Snort, Suricata).
- **IPS (Intrusion Prevention):** active blocking of detected threats.
- **Detection methods:** signature-based (known patterns) vs anomaly-based (baseline deviation).
- **Evasion techniques:** fragmentation, encoding, timing attacks, encrypted payloads.

Defenses (one-liners)

- Stateful firewall with default-deny policy
- IDS/IPS with updated signature sets
- Deep packet inspection and reassembly
- Network segmentation and zero-trust architecture

Exam lines

- Stateful firewall tracks **connection state** (unlike stateless packet filter).
- IDS = **detect and alert**; IPS = **detect and block**.
- Signature-based IDS matches **known attack patterns** (Snort rules).
- Anomaly-based IDS detects **deviations from baseline** behavior.
- Fragmentation evades IDS that doesn't **reassemble packets** before inspection.

L40: DNS and Email Security

What it is / what it does

- **DNS record types:** A, AAAA, MX, NS, TXT, CNAME, PTR, SOA.
- **DNSSEC:** cryptographically signs DNS records (RRSIG, DNSKEY, DS); prevents spoofing.
- **Email security protocols:** SPF (authorized senders), DKIM (signed messages), DMARC (policy enforcement).
- **SPF:** TXT record listing permitted sending IPs for domain.

- **DKIM:** digital signature in email header; verified against public key in DNS TXT.
- **DMARC:** policy telling receivers what to do with SPF/DKIM failures (none/quarantine/reject).

Defenses (one-liners)

- Implement SPF + DKIM + DMARC (p=reject)
- Enable DNSSEC on all zones
- Monitor DMARC aggregate reports
- Lock domain registrar account with MFA

Exam lines

- SPF = **authorized sending IP addresses** for a domain.
- DKIM = **cryptographic signature** on email headers/body.
- DMARC = **policy** for handling SPF/DKIM failures.
- DNSSEC prevents **DNS response spoofing** via digital signatures.
- MX record specifies **mail server** for domain.

Contents

Volume 05 — System Attacks & Hardware Security (L41–L50) **1**
L41: Password Cracking . . . 1
L42: Phishing Attack . . . 2
L43: Malware . . . 2
L44: Wi-Fi Hacking . . . 3
L45: DoS and DDoS Attack . . . 4
L46: Elements of Hardware Security . . . 4
L47: Side Channel Attacks — Part I . . . 5
L48: Side Channel Attacks — Part II . . . 5
L49: Physical Unclonable Function . . . 6
L50: Hardware Trojan . . . 7

Volume 05 — System Attacks & Hardware Security (L41–L50)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Passwords, phishing, malware, Wi-Fi, DoS, side channels, PUF, hardware trojans.

L41: Password Cracking

What it is / what it does

- **Password storage:** never plaintext; hash with salt + slow algorithm (bcrypt, Argon2).
- **Windows hashes:** LM (obsolete, case-insensitive, 7-char chunks) and NTLM (MD4 of UTF-16LE password).
- **Linux hashes:** MD5 (1), SHA-256 (5), SHA-512 (6), bcrypt ($2a$), yescrypt.
- **Attack types:** dictionary, brute-force, hybrid, rule-based, rainbow tables.
- **Pass-the-hash:** authenticate using NTLM hash without cracking plaintext.

Defenses (one-liners)

- Password policy: length ≥ 12, complexity, no common passwords
- MFA on all accounts
- Account lockout / rate limiting
- Use Argon2id/bcrypt for application password storage

Exam lines

- NTLM hash = **MD4** of password; Hashcat mode **1000**.
- Dictionary attack tries **wordlist entries**; brute-force tries all combinations.
- Rainbow tables are precomputed — defeated by **salting**.
- Pass-the-hash uses **NTLM hash directly** without cracking plaintext.

- LM hash splits password into **7-character chunks** (case-insensitive).

L42: Phishing Attack

What it is / what it does

- **Phishing types:** mass phishing, spear phishing (targeted), whaling (executives), vishing (voice), smishing (SMS).
- **Attack chain:** recon → craft lure → deliver payload → capture credentials → establish access.
- **Indicators:** mismatched URLs, urgency language, generic greetings, suspicious attachments.
- **Clone phishing:** copy legitimate email, replace links/attachments with malicious versions.
- **Business Email Compromise (BEC):** impersonate executive to authorize wire transfers.

Defenses (one-liners)

- Security awareness training with simulated phishing
- SPF + DKIM + DMARC (p=reject)
- Email gateway filtering and link sandboxing
- MFA (hardware tokens resist Evilginx2 better than SMS)

Exam lines

- Spear phishing targets **specific individuals** with personalized content.
- Clone phishing **replicates legitimate emails** with malicious modifications.
- Evilginx2 performs **AiTM (adversary-in-the-middle)** to steal session cookies.
- DMARC p=reject blocks emails failing **SPF and DKIM** checks.
- Whaling targets **C-level executives** (high-value targets).

L43: Malware

What it is / what it does

- **Malware categories:** virus (needs host), worm (self-replicating), trojan (disguised), ransomware, spyware, rootkit, adware.
- **Propagation:** email attachments, drive-by download, USB, exploit kits, lateral movement.
- **Persistence mechanisms:** registry Run keys, scheduled tasks, services, DLL hijacking, firmware.
- **Anti-analysis:** packing, obfuscation, VM/sandbox detection, encrypted strings.
- **RAT (Remote Access Trojan):** provides attacker remote control (DarkComet, njRAT, Cobalt Strike).

Defenses (one-liners)

- Endpoint Detection and Response (EDR)
- Application whitelisting
- Disable macros by default in Office
- Network monitoring for C2 beacon patterns

Exam lines

- Virus requires **host program**; worm spreads **autonomously**.
- Trojan **disguises** as legitimate software (user-initiated execution).
- Rootkit operates at **kernel/firmware level** — hides from OS.
- Packing/obfuscation defeats **signature-based** AV detection.
- RAT provides **remote access and control** over infected system.

L44: Wi-Fi Hacking

What it is / what it does

- **802.11 standards:** a (5 GHz), b/g (2.4 GHz), n (MIMO), ac/ax (Wi-Fi 5/6).
- **Authentication:** Open, WEP (broken), WPA (TKIP, deprecated), WPA2 (AES-CCMP), WPA3 (SAE).
- **4-way handshake:** AP ↔ client key exchange; captures used for offline cracking.
- **Monitor mode:** NIC captures all wireless frames (not just associated BSS).
- **Deauthentication attack:** forged deauth frames disconnect clients (capture handshake on reconnect).

Defenses (one-liners)

- WPA3 with SAE (resistant to offline dictionary attacks)
- Strong passphrase (≥ 15 random characters)
- 802.11w (protected management frames) prevents deauth attacks
- Enterprise WPA2-Enterprise (802.1X/RADIUS) — per-user credentials

Exam lines

- WEP uses **RC4** — cracked in minutes; never use.
- WPA2-PSK crack requires capturing **4-way handshake** or PMKID.
- Deauth attack sends forged **deauthentication frames** to disconnect clients.
- Monitor mode captures **all wireless traffic** on channel (promiscuous for Wi-Fi).
- WPA3 SAE replaces PSK with **dragonfly key exchange** (anti offline-dict).

L45: DoS and DDoS Attack

What it is / what it does

- **DoS:** single source overwhelms target; **DDoS:** distributed attack from botnet (zombies).
- **Attack types:**
- Volume-based: UDP flood, ICMP flood, DNS amplification
- Protocol-based: SYN flood, Ping of Death
- Application-layer: HTTP flood, Slowloris, RUDY
- **Amplification:** small query → large response (DNS, NTP, memcached reflection).
- **Botnet:** network of compromised machines (Mirai, Emotet) controlled by C2 server.

Defenses (one-liners)

- SYN cookies (kernel-level SYN flood mitigation)
- Rate limiting and traffic shaping
- CDN/DDoS scrubbing services (Cloudflare, Akamai)
- Anycast distribution to absorb volume

Exam lines

- SYN flood exploits **TCP 3-way handshake** — fills connection queue with half-open connections.
- DNS amplification achieves **bandwidth multiplication** (small query, large response).
- Slowloris is **application-layer** attack — holds connections with incomplete requests.
- Botnet = **network of compromised machines** controlled by attacker (C2).
- DDoS mitigation: **rate limiting + CDN scrubbing + SYN cookies**.

L46: Elements of Hardware Security

What it is / what it does

- **Hardware root of trust:** secure boot chain from immutable ROM (TPM, secure enclave).
- **TPM (Trusted Platform Module):** hardware chip storing keys, measurements, attestation.
- **Secure boot:** verify firmware/OS signatures before execution (UEFI Secure Boot).
- **Hardware Security Module (HSM):** dedicated crypto processor for key management.
- **TrustZone (ARM) / SGX (Intel):** isolated execution environments (TEE).

Defenses (one-liners)

- Enable UEFI Secure Boot with vendor + custom keys

- TPM-based disk encryption (BitLocker, LUKS with TPM binding)
- Disable JTAG/debug interfaces in production
- Physical tamper detection (enclosure switches, epoxy)

Exam lines

- TPM provides **hardware root of trust** for key storage and attestation.
- Secure Boot verifies **digital signatures** of firmware/OS before loading.
- HSM = dedicated hardware for **crypto key management** (high-security environments).
- TrustZone/SGX create **Trusted Execution Environments** isolated from main OS.
- Evil maid attack: physical access to **tamper with boot process**.

L47: Side Channel Attacks — Part I

What it is / what it does

- **Side-channel attack:** exploit physical implementation leakage, not algorithm weakness.
- **Power analysis:** measure power consumption during crypto operations.
- **SPA (Simple Power Analysis):** visual inspection of power traces.
- **DPA (Differential Power Analysis):** statistical correlation of traces with key bits.
- **Timing attack:** measure operation duration to infer secret data (Kocher 1996).
- **Electromagnetic (EM) leakage:** capture EM emissions from chip during computation.

Defenses (one-liners)

- **Masking:** randomize intermediate values in crypto operations
- **Constant-time implementations:** prevent timing variations
- **Power/EM shielding:** Faraday cage, filtering capacitors
- **Noise injection:** add random operations to obscure signal

Exam lines

- Side-channel attacks exploit **physical leakage** (power, timing, EM), not math weaknesses.
- DPA uses **statistical analysis** of many power traces to recover key bits.
- SPA requires **visual inspection** of single/few power traces.
- Timing attack: measure **operation duration** to infer secret (e.g., RSA key bits).
- Constant-time code prevents **timing side channels**.

L48: Side Channel Attacks — Part II

What it is / what it does

- **Cache timing attacks:** exploit CPU cache behavior (Flush+Reload, Prime+Probe).

- **Spectre/Meltdown:** CPU speculative execution leaks data across security boundaries.
- **Acoustic cryptanalysis:** recover RSA keys from coil whine (disk encryption).
- **Fault injection:** glitch voltage/clock/laser to cause computation errors → leak key material.
- **Rowhammer:** repeatedly access DRAM rows to flip bits in adjacent rows.

Defenses (one-liners)

- Microcode updates for Spectre/Meltdown mitigations
- Cache partitioning (CAT — Cache Allocation Technology)
- ECC memory against Rowhammer
- Double-and-add randomization in crypto implementations

Exam lines

- Meltdown breaks **user/kernel isolation** via speculative execution.
- Spectre tricks programs into **leaking data** via mispredicted branches.
- Rowhammer exploits **DRAM physical proximity** to flip bits without direct access.
- Fault injection (voltage/clock glitch) causes **computation errors** revealing key material.
- Flush+Reload is a **cache timing attack** on shared cache lines.

L49: Physical Unclonable Function

What it is / what it does

- **PUF (Physical Unclonable Function):** hardware instance-specific challenge-response based on manufacturing variations.
- **Types:** SRAM PUF (power-on state), ring oscillator PUF, arbiter PUF, optical PUF.
- **Properties:** uniqueness (different chips → different responses), reliability (same challenge → same response), unclonability.
- **Applications:** device authentication, key generation, anti-counterfeiting, secure boot binding.
- **FPGA/IC fingerprinting:** identify specific hardware instance without stored secret.

Defenses (one-liners)

- Helper data schemes (fuzzy extractors) for error correction without revealing PUF
- Limit exposed challenge-response pairs (prevent modeling)
- Combine PUF with secure enclave
- Environmental monitoring to detect tampering

Exam lines

- PUF exploits **manufacturing variations** for unique device identity.
- PUF response is **unclonable** — cannot replicate on different chip.

- SRAM PUF uses **power-on random state** of uninitialized SRAM.
- Modeling attack uses **ML on C-R pairs** to clone PUF behavior.
- PUF used for **device authentication** and **key derivation**.

L50: Hardware Trojan

What it is / what it does

- **Hardware Trojan:** malicious modification to IC/hardware at design, fabrication, or assembly stage.
- **Trojan types:** functional (change behavior) vs parametric (degrade performance); trigger: always-on, condition-based.
- **Insertion points:** RTL design, synthesis, placement, fabrication (untrusted foundry).
- **Payloads:** information leakage, denial of service, privilege escalation, kill switch.
- **Detection difficulty:** no equivalent of AV for hardware; golden chip comparison required.

Defenses (one-liners)

- Trusted foundry and supply chain verification
- Split manufacturing (no single entity has full design)
- Runtime monitoring for anomalous behavior
- Formal verification of RTL against golden reference

Exam lines

- Hardware Trojan inserted at **design, fabrication, or assembly** stage.
- Functional Trojan **changes circuit behavior**; parametric degrades performance.
- Trigger types: **always-on** or **condition-based** (rare input pattern).
- Untrusted foundry is primary threat in **offshore chip manufacturing**.
- Detection requires **golden chip comparison** or side-channel anomaly analysis.

Contents

Volume 06 — Web Vulns, Nmap & Wireshark (L51–L62) **1**
L51: Web Application Vulnerability Scanning 1
L52: SQL Injection — Authentication Bypass Part 1 2
L53: SQL Injection — Error Based Part 2 2
L54: SQL Injection — Error Based from Web Application Part 3 3
L55: SQLMAP 4
L56: Cross Site Scripting 4
L57: File Upload Vulnerability 5
L58: The NMAP Tool — A Relook Part I 5
L59: The NMAP Tool — A Relook Part II 6
L60: The NMAP Tool — A Relook Part III 7
L61: Network Analysis Using Wireshark 7
L62: Summarization of the Course 8

Volume 06 — Web Vulns, Nmap & Wireshark (L51–L62)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Web scanning, SQLi, XSS, file upload, Nmap/Wireshark roles, course wrap-up.

L51: Web Application Vulnerability Scanning

What it is / what it does

- **OWASP Top 10:** injection, broken auth, sensitive data exposure, XXE, broken access control, misconfig, XSS, insecure deserialization, vulnerable components, insufficient logging.
- **Web app architecture:** browser → web server → application server → database.
- **Scanning types:** passive (spider/crawl), active (inject payloads), authenticated (with credentials).
- **False positives:** scanner reports vulnerability that doesn't exist — always verify manually.
- **Scope:** stay within authorized URLs/parameters defined in engagement rules.

Defenses (one-liners)

- WAF (Web Application Firewall) — ModSecurity, Cloudflare
- Regular automated scanning in CI/CD pipeline
- Input validation and output encoding
- Keep frameworks and libraries patched

Exam lines

- OWASP Top 10 lists most **critical web application risks**.

- Burp Suite acts as **intercepting proxy** between browser and server.
- Active scanning **sends attack payloads**; passive only observes traffic.
- Directory brute-forcing discovers **hidden pages and admin panels**.
- Always **verify scanner findings** manually before reporting.

L52: SQL Injection — Authentication Bypass Part 1

What it is / what it does

- **SQL Injection (SQLi):** insert malicious SQL into application query via unsanitized user input.
- **Root cause:** string concatenation of user input into SQL query.
- **Authentication bypass:** inject SQL that makes WHERE clause always true.
- **Injection points:** login forms, search boxes, URL parameters, HTTP headers, cookies.
- **Types:** in-band (results in response), blind (no direct output), out-of-band (DNS/HTTP exfiltration).

Defenses (one-liners)

- **Parameterized queries (prepared statements)** — never concatenate user input
- Input validation (whitelist allowed characters)
- Least-privilege database accounts (no DROP/UNION privileges)
- WAF with SQLi rules (secondary defense, not primary)

Exam lines

- SQLi root cause: **unsanitized user input concatenated** into SQL query.
- ’ OR ‘1’=’1 makes WHERE clause **always true** → bypasses authentication.
- – (double dash) is SQL **comment** — ignores rest of query.
- **Prepared statements** separate SQL structure from data (primary defense).
- Single quote ’ in input often triggers **SQL error** revealing vulnerability.

L53: SQL Injection — Error Based Part 2

What it is / what it does

- **Error-based SQLi:** exploit verbose SQL error messages to extract database information.
- **MySQL functions:** extractvalue(), updatexml(), floor() + rand() for error-based extraction.
- **Information gathering:** database name, table names, column names, data values.
- **UNION-based injection:** append UNION SELECT to extract data from other tables.
- **UNION requirements:** same number of columns, compatible data types.

Defenses (one-liners)

- Disable verbose error messages in production (custom error pages)
- Parameterized queries / ORM with parameter binding
- Database user with minimal privileges (no information_schema access)
- WAF blocking UNION, extractvalue, information_schema keywords

Exam lines

- Error-based SQLi exploits **verbose database error messages** for data extraction.
- UNION SELECT requires **matching column count** and compatible types.
- ORDER BY N– technique finds **number of columns** in query.
- information_schema.tables reveals **table names** in MySQL.
- extractvalue() forces **XPath error** containing injected data (MySQL).

L54: SQL Injection — Error Based from Web Application Part 3

What it is / what it does

- **Practical exploitation workflow** on DVWA, WebGoat, or custom vulnerable apps.
- **DVWA security levels:** Low (no filtering) → Medium (basic filter) → High (CSRF token) → Impossible (prepared statements).
- **Filter bypass techniques:**
- Case variation: UnIoN SeLeCt
- Comment injection: UN/**/ION SELECT
- URL encoding: %27 OR %271%27=%271
- Double encoding, hex encoding
- **Blind SQLi introduction:** boolean-based (AND 1=1 vs AND 1=2) and time-based (SLEEP(5)).

Defenses (one-liners)

- Prepared statements at all security levels (DVWA “Impossible” level)
- Input type validation (integer fields → cast to int)
- CSRF tokens prevent automated exploitation (not a SQLi fix alone)
- Comprehensive WAF rules + rate limiting

Exam lines

- Numeric injection: no quotes needed when input is **not string-quoted** in query.
- Filter bypass: **case variation, comment injection, encoding**.
- Blind SQLi: **no error messages** — infer from response differences or timing.
- SLEEP(5) = **time-based blind** SQLi (MySQL).
- CSRF token protects form submission but **does not prevent SQLi** if token is obtained.

L55: SQLMAP

What it is / what it does

- **sqlmap:** automated SQL injection and database takeover tool.
- **Detection engine:** tests all SQLi types (boolean, error, union, stacked, time-based).
- **DBMS support:** MySQL, PostgreSQL, MSSQL, Oracle, SQLite, and more.
- **Post-exploitation:** dump tables, read files, OS shell (via stacked queries/UDF).
- **Tamper scripts:** modify payloads to evade WAF/filtering.

Defenses (one-liners)

- Parameterized queries (makes sqlmap detection fail)
- WAF blocking sqlmap signatures (User-Agent, request patterns)
- Database least privilege (no FILE privilege, no xp_cmdshell)
- Monitor for sqlmap User-Agent and timing-based scan patterns

Exam lines

- –dbs enumerates databases; –dump extracts **table data**.
- –os-shell requires **stacked queries** and DBA-level privileges.
- Tamper scripts (–tamper) modify payloads to **evade WAF filters**.
- –batch runs with **default answers** (non-interactive mode).

L56: Cross Site Scripting

What it is / what it does

- **XSS:** inject malicious JavaScript into web page viewed by other users.
- **Types:**
- **Reflected:** payload in URL/form; executed immediately (non-persistent).
- **Stored:** payload saved in database; executed for every visitor (persistent).
- **DOM-based:** client-side JavaScript processes untrusted input without server round-trip.
- **Impact:** session hijacking (cookie theft), defacement, keylogging, phishing, redirect.
- **Cookie theft:**
  .

Defenses (one-liners)

- **Output encoding** (HTML entity encode user data before rendering)
- Content Security Policy (CSP): script-src ‘self’
- HttpOnly flag on session cookies (prevents JavaScript access)
- Input validation (secondary defense — encoding is primary)

Exam lines

- Stored XSS is **persistent** — affects all users viewing the page.
- Reflected XSS requires **victim to click malicious link**.
- DOM-based XSS: vulnerability in **client-side JavaScript** (no server involvement).
- HttpOnly cookie flag prevents **JavaScript cookie theft**.
- CSP script-src restricts **which scripts can execute** on the page.

L57: File Upload Vulnerability

What it is / what it does

- **Unrestricted file upload:** server accepts any file type → attacker uploads web shell.
- **Web shell:** PHP/ASP/JSP script providing remote command execution on server.
- **Bypass techniques:**
- Double extension: shell.php.jpg
- MIME type spoofing: Content-Type: with PHP content
- Null byte: shell.php%00.jpg (legacy)
- Case variation: shell.PhP
- Polyglot file: valid image header + embedded PHP code
- **Impact:** remote code execution (RCE), server compromise, data theft.

Defenses (one-liners)

- Whitelist allowed extensions (not blacklist)
- Validate file content (magic bytes), not just extension/MIME
- Store uploads outside webroot; serve via separate domain
- Rename uploaded files (remove user-controlled names)

Exam lines

- Web shell provides **remote command execution** on the server.
- Whitelist validation is **stronger than blacklist** for file types.
- MIME type can be **spoofed** — validate magic bytes/content.
- Store uploads **outside webroot** to prevent direct execution.
- Polyglot file is valid image **and** contains executable code.

L58: The NMAP Tool — A Relook Part I

What it is / what it does

- **Host discovery deep-dive:** ARP scan (local), ICMP echo/timestamp/netmask, TCP SYN/ACK ping, UDP ping.
- **ARP scan (-PR):** most reliable on local LAN; doesn't traverse routers.
- **ICMP types:** echo (type 8), timestamp (13), netmask (17) — -PE, -PP, -PM.
- **TCP ping:** SYN to port 80 (-PS80), ACK to port 443 (-PA443).

- **List scan (-sL):** DNS resolution only, no packets to target (stealthiest).

Defenses (one-liners)

- Block ICMP at perimeter (note: -Pn bypasses discovery anyway)
- Monitor ARP traffic for scanning patterns
- Honeypot IPs in unused address space to detect scans

Exam lines

- ARP scan (-PR) works only on **local Ethernet segment**.
- -Pn skips host discovery — treats **all hosts as up**.
- -sL performs **reverse DNS only** — no packets to targets.
- ICMP echo = -PE; TCP SYN ping = -PS.
- Multiple discovery methods increase reliability through **firewalls**.

L59: The NMAP Tool — A Relook Part II

What it is / what it does

- **Port scan techniques recap:**
- -sS SYN (half-open, stealthy, requires root)
- -sT Connect (full handshake, logged)
- -sU UDP (slow, ICMP port unreachable = closed)
- -sN NULL, -sF FIN, -sX Xmas (RFC 793 behavior)
- **Port specification:** -p 22,80,443, -p 1-1000, -p- (all 65535), –top-ports 100.
- **Speed templates:** -T0 (paranoid) to -T5 (insane); default T3.
- **Parallelism:** –min-parallelism, –max-parallelism, –min-rate.

Defenses (one-liners)

- Port knocking for sensitive services
- Firewall default-deny with allowlist
- IDS rate-based alerting on -T4/-T5 scans
- Reduce attack surface (close unused ports)

Exam lines

- -sS = SYN scan; **half-open**, doesn’t complete handshake.
- -p- scans **all 65535 ports** (TCP or UDP depending on scan type).
- -T0 to -T5 control **scan speed** (T0 = slowest/stealthiest).
- NULL/FIN/Xmas scans exploit **RFC 793** response behavior.
- –reason shows **why** nmap classified port as open/closed/filtered.

L60: The NMAP Tool — A Relook Part III

What it is / what it does

- **Service/version detection (-sV):** probe open ports, match against nmap-service-probes database.
- **OS detection (-O):** TCP/IP stack fingerprinting (TTL, window size, TCP options).
- **NSE (Nmap Scripting Engine):** –script=default,vuln,auth.
- **Output and reporting:** -oA basename (all formats), –stylesheet for HTML.
- **Advanced evasion:** –data-length, –ip-options, –source-port, –proxies.

Defenses (one-liners)

- Keep services updated (version detection reveals patch level)
- OS fingerprint obfuscation (some OS allow TTL/window customization)
- NSE script detection at IPS/WAF layer
- Minimize exposed service information (remove banners)

Exam lines

- -sV probes open ports for **service name and version**.
- -O requires **at least one open and one closed port** for OS detection.
- -A = aggressive: OS + version + scripts + traceroute + **not stealthy**.
- -oA saves in **all formats** (normal, XML, grepable).
- NSE –script vuln runs **vulnerability detection** scripts.

L61: Network Analysis Using Wireshark

What it is / what it does

- **Wireshark:** GUI packet analyzer; captures and dissects traffic at frame level.
- **Capture filters (BPF):** applied during capture — host 192.168.1.1, port 80, tcp port 443.
- **Display filters:** applied post-capture — http, tcp.flags.syn==1, ip.addr==x.
- **Follow TCP/UDP stream:** reassemble conversation for readable analysis.
- **Use cases:** troubleshoot connectivity, detect malware C2, analyze attacks, forensic investigation.

Defenses (one-liners)

- Encrypt all traffic (TLS) — Wireshark sees only metadata without keys
- Network monitoring with automated anomaly detection
- Full packet capture (FPC) appliances for forensic retention
- DNS logging and Sinkholing for C2 detection

Exam lines

- Capture filter (BPF) applied **during** capture; display filter **after**.

- tcp.flags.syn==1 filters **SYN packets** (scan detection).
- Follow TCP Stream **reassembles** entire conversation for reading.
- Wireshark cannot decrypt TLS without **session keys** (SSLKEYLOGFILE).
- tshark is Wireshark's **command-line** counterpart.

L62: Summarization of the Course

What it is / what it does

- **Course arc recap:**

Exam lines

- Pentest phases: **recon → scan → exploit → maintain → report**.
- Defense-in-depth: multiple **independent security layers**.
- CIA triad + authentication + non-repudiation = core security goals.
- Always obtain **written authorization** before any security testing.
- Keep tools updated: Nmap NSE, Nessus plugins, Metasploit modules, sqlmap tamper scripts.
